# Examen CRYPTA

Durée : 2h

7 février 2025

Notes manuscrites et planches des cours ISEC et CRYPTA autorisées à l'exclusion de toute autre document.

L'utilisation de tout matériel électronique (en dehors d'une montre non connectée) est interdite.

Il y a quatre exercices indépendants.

Une rédaction claire et concise sera appréciée. Toute affirmation devra être justifiée.

Une question non résolue n'empêche pas de faire les suivantes. (dans ce cas indiquez clairement que vous admettez le(s) résultat(s) de la question non faite).

Le sujet est certainement trop long ; traitez les exercices que vous préférez d'abord.

## 1 Chiffrement RSA avec petits textes clairs

Nous rappelons le système de chiffrement RSA naïf vu en cours :

**Chiffrement RSA naïf**

**Génération des clés :** L'utilisateur tire aléatoirement deux nombres premiers $p$ et $q$ (distincts et de même longueur binaire) et calcule $N = pq$. Il calcule $\varphi(N) = (p-1)(q-1)$, la fonction indicatrice d'Euler de $N$. Il choisit un exposant public $e$ premier à $\varphi(N)$ et calcule $d$ l'inverse de $e$ modulo $\varphi(N)$. La clé (publique) de chiffrement est le couple $(N, e)$ et la clé (secrète) de déchiffrement est l'entier $d$.

**Chiffrement :** étant donné un message $m \in (\mathbb{Z}/N\mathbb{Z})^*$, l'algorithme de chiffrement retourne le chiffré $c = m^e \bmod N$.

**Déchiffrement :** étant donné un chiffré $c \in (\mathbb{Z}/N\mathbb{Z})^*$ et la clé secrète $d$, l'algorithme de déchiffrement retourne $c^d \bmod N$.

▷ **Question 1:** Montrer que décrypter (sans posséder la clef secrète) un message $m \in (\mathbb{Z}/N\mathbb{Z})^*$ chiffré par la fonction RSA $f_{N,e}$ est immédiat si $m^e < N$.

▷ **Question 2:** Supposons que $m = ab$ avec $a, b < T$ pour $T \in \mathbb{N}$. Proposer un algorithme par compromis temps-mémoire qui étant donné le chiffré $c = m^e \bmod N$ retrouve le message clair $m$ en $\mathcal{O}(T)$ évaluations de la fonction RSA $f_{N,e}$ avec $\mathcal{O}(T)$ éléments de $(\mathbb{Z}/N\mathbb{Z})^*$ en mémoire.

---

Posons (où le symbole # désigne la cardinalité de l'ensemble) :

$$\theta(T) = \#\{m \in \mathbb{N} \mid m = ab \text{ et } a, b \leq T\}.$$

Nous admettons la conséquence du théorème des nombres premiers sous la forme explicite suivante :

$$3x/(5\ln(x)) < \pi(2x) - \pi(x)$$

pour tout nombre réel $x > 50$ où $\pi(y)$ désigne le nombre de nombres premiers inférieur à $y$.

▷ **Question 3:** En considérant les produits de la forme $\ell \cdot t$ avec $T/2 < \ell < T$ et $t < T/2$ où $\ell$ est un nombre premier, montrer que $\theta(T) \geq \frac{3}{20}T^2/(\ln(T/2))$ pour $T > 100$ .

▷ **Question 4:** Supposons qu'une clé AES aléatoire $k$ de 128 bits est chiffrée avec le protocole de chiffrement RSA naïf (en interprétant la chaine de 128 bits comme un entier de 128 bits). Montrer que $k$ peut être retrouvée en $2^{65}$ évaluations de la fonction RSA avec probabilité supérieure à 0.3%.

**Indication :** On pourra utiliser le fait que $\ln(2) \simeq 0,69$.

## 2 Cryptanalyse d'un PRNG

Voici, à très peu de choses près, le générateur pseudo-aléatoire qu'on trouve dans le "moteur" JavaScript V8 (développé par Google), dans les versions antérieures à la 4.9.49 (dans `src/js/jsmath.js`). Il a été depuis remplacé par un autre.

**Générateur pseudo-aléatoire dans Google V8 (v4.9.48)**

```
u16 a, b, c, d;

u32 mwc1616() {
  u32 r0 = 18030 * a + b;
  u32 r1 = 36969 * c + d;
  a = r0 & 0xFFFF;
  b = r0 >> 16;
  c = r1 & 0xFFFF;
  d = r1 >> 16;
  return r0 ^ r1;
}
```

▷ **Question 5:** Supposons que son état interne ($a$, $b$, $c$ et $d$) soit correctement initialisé avec des bits aléatoires. Expliquez, de manière détaillée, pourquoi ce n'est pas un générateur pseudo-aléatoire de qualité cryptographique (une page manuscrite maximum).

## 3 Clefs publiques RSA promotionnelles

Vous travaillez chez CryptoBit, une entreprise du secteur de la sécurité. Votre rival traditionnel, CryptoLock, a fait un coup de comm' qui fait buzzer tout le darknet : ils se sont fabriqué une paire de clefs RSA personnalisée, où les bits de poids forts du modulus $N$ ont une valeur (promotionnelle) spécifique. Plus précisément, le $N$ de leur clef RSA figure ci-dessous. On suppose que $N = pq$, et que $p$ et $q$ font 1024 bits chacun.

**La clef publique de l'entreprise rivale**

```
5731 7468 2043 7279 7074 304c 3063 6b2c  W1th CryptOLOck,
2079 3075 7220 6434 7434 2034 7265 2073   yOur d4t4 4re s
3466 3372 2074 6834 6e20 3376 3372 0000  4f3r th4n 3v3r..
0000 0000 0000 0000 0000 0000 0000 0000  ................
0000 0000 0000 0000 0000 0000 0000 0000  ................
0000 0000 0000 0000 0000 0000 0000 0000  ................
0000 0000 0000 0000 0000 0000 0000 0000  ................
0000 0000 0000 0000 0000 0000 0000 00f9  ................
30c6 7d8f 1345 a037 7235 a7ea 6de3 c142  0.}..E.7r5..m..B
f456 e643 e62e 4608 e4a9 7365 61e4 9d5e  .V.C..F...sea..^
5824 f64f 8f7f df42 95c4 9c61 95de 9df5  X$.O...B...a....
7952 5b43 32c6 cfd1 ab6f 99d8 e98b c22c  yR[C2....o.....,
3d04 e5bc 4b06 c93f e2a6 900f 5296 2bdd  =...K..?....R.+.
d7c1 89d0 5c84 3f3f ef5e 8703 3b8d e8df  ....\.??.^..;...
4b1d 5c52 cd64 7b99 48be 457d f3f2 a800  K.\R.d{.H.E}....
4d77 2021 bc27 4093 cd8d 436b 6618 282d  Mw !.'@...Ckf.(-
```

▷ **Question 6:** En examinant la tête de cette clef publique RSA, essayez de comprendre comment l'entreprise rivale a-t-elle bien pu s'y prendre pour choisir $p$ et $q$. (le "stagiaire" que vous avez fait recruter là-bas pour ~~récolter du renseignement industriel~~ suivre une formation affirme qu'ils ont sûrement choisi $p$ normalement, dans un premier temps, puis qu'ils ont calculé $q$ à partir de $p$ et des contraintes sur $N$ dans un deuxième temps).

▷ **Question 7:** Avec cette technique, combien de bits de poids fort de $N$ peut-on choisir arbitrairement au maximum ?

▷ **Question 8:** Le procédé en question, tel qu'il a été mis en oeuvre, a un gros défaut : la clef n'est pas sûre du tout ! Expliquez comment réduire en miette la réputation de l'entreprise rivale en factorisant sa clef publique.

▷ **Question 9:** Proposez une manière de réparer le procédé en question, pour que les clefs soient sûres malgré tout.

# 4 Signature RSA avec bourrage constant

On considère un schéma de signature basé sur RSA. Le modulus $N$ fait $n$ bits de long, et on considère un autre entier $M$, sensiblement plus petit que $N$. Les messages qu'on peut signer sont les entiers compris entre zéro et $M-1$. Il y a aussi une constante $P$, qui est un nombre fixé, plus grand que $M$. La signature d'un message $m$ est $s := (P+m)^d \bmod N$.

Pour fixer les idées, on peut imaginer $N$ de 2048 bits, $M = 2^{1536}$, $P =$ `0xDeadBeef0000FFFF0000.....0000FFFF` (2048 bits de long).

▷ **Question 10:** Comment vérifie-t-on que la signature est correcte ?

▷ **Question 11:** Rappelez comment fonctionne l'attaque triviale par malléabilité sur la signature RSA naïve ("textbook"). L'ajout du bourrage $P$ l'empêche-t-elle ?

---

On va maintenant voir une attaque qui permet de contrefaire des signatures. Supposons qu'on dispose de trois messages $m_1, m_2$ et $m_3$ ainsi que des signatures $s_1, s_2$ et $s_3$ correspondantes.

Clairement, on a $s_1 \equiv s_2 s_3 \bmod N$ si et seulement si $(P+m_1) \equiv (P+m_2)(P+m_3) \bmod N$. L'attaque fonctionne de la façon suivante : on choisit $m_3$ de manière arbitraire, puis on va calculer (par un moyen qui reste à déterminer) $m_1$ et $m_2$ qui satisfont la relation ci-dessus et les contraintes de taille.

▷ **Question 12:** Pourquoi cela casse-t-il la sécurité du schéma de signature ? Quelle notion précise de sécurité est-elle brisée ?

▷ **Question 13:** Une stratégie naïve consisterait à choisir $m_1$ au hasard puis calculer $m_2$ pour que la relation soit satisfaite. La contrainte sur la taille de $m_2$ va-t-elle être forcément satisfaite ? Si non, y a-t-il beaucoup de chance qu'elle le soit ?

▷ **Question 14:** En fait, il faut fabriquer $m_1$ et $m_2$ en même temps pour satisfaire les contraintes sur leur taille systématiquement. Ceci peut se faire en résolvant une instance de CVP sur un réseau euclidien de dimension deux. Explicitez la base d'un réseau qui contient un point $\mathbf{x} = (m_1, m_2)$, où $m_1$ et $m_2$ satisfont toutes les contraintes. Donnez également les coordonnées d'un vecteur $\mathbf{y}$ calculable à partir des informations publiques qui est "assez proche" de $\mathbf{x}$.

▷ **Question 15:** Justifiez que résoudre CVP sur le réseau à partir de $\mathbf{y}$ révèle bien $\mathbf{x}$, et donc casse le schéma de signature.